TARMOQ XAVFSIZLIGI

A12. DDoS hujumlaridan himoyalanish choralarini loyihalash

1-VARIANT — Veb-xizmat uchun qatlamli himoya va nazoratli sinov

Mashg‘ulot maqsadi. Talaba veb-xizmatning mavjudligiga tahdidlarni ajratadi, Nginx reverse proxy orqali HTTP so‘rov tezligini cheklaydi, himoyadan oldingi va keyingi natijalarni taqqoslaydi. Tajriba dalillari asosida mahalliy server, ilova va provayder darajasidagi DDoS himoya rejasini ishlab chiqadi.

Senariy. Universitetning o‘quv portali uchun oddiy mijoz kirishini saqlagan holda takroriy tezkor so‘rovlarni cheklash talab etiladi. Bitta Ubuntu VM ichida ikki alohida IPli mijoz, Nginx va mahalliy backend yaratiladi. Biri oddiy foydalanuvchini, ikkinchisi esa chegaralangan sinov yuklamasini ifodalaydi.

Ko‘rsatkich	Ushbu variant
Semestr / hajm	5-semestr; 2 akademik soat
Vaqt	Tayyor Ubuntu obrazi va kod fayllari bilan taxminan 80 daqiqa
Xona	30 ta Windows 11 host; har talabaga mustaqil laboratoriya
Host	8 yadroli CPU; 32 GB RAM; 1 TB SSD; LAN va Internet
VM	Ubuntu Server 24.04 LTS; 2 vCPU, 4 GB RAM, 25 GB disk
Vositalar	VMware/VirtualBox; Nginx OSS, Python 3, iproute2, curl
Natija	Himoya konfiguratsiyasi, CSV va loglar, hisob-kitob, javob rejasi

Kutiladigan o‘quv natijalari

- HTTP 429 javobi bilan xizmatning buzilishi sababli yuzaga kelgan xatoni log orqali farqlash; oddiy mijoz muvaffaqiyat ulushini hisoblash.
- Manba IP bo‘yicha limitning foydasi va NAT, ko‘p manbali trafik hamda kanal to‘lishiga nisbatan cheklovlarini tushuntirish.
- Himoyani kuzatuv rejimidan faol rejimga o‘tkazish; xizmat ishlashini tekshirish va qaytarish rejasini tuzish.

Tajriba chegarasi. Bu kichik HTTP yuklamasi bilan himoya mexanizmini tekshiruvchi laboratoriya; to‘liq DDoS bardoshlilik sinovi emas. Bitta tezkor manba va bitta oddiy mijoz ishlatiladi. Real universitet serveri, xona LANi va Internet manzillari sinov nishoni bo‘lmaydi. Volumetrik va ko‘p manbali ssenariylar loyihalash qismida tahlil qilinadi.

1. Tahdid modeli va muhitni tayyorlash

Tahdid turi	Asosiy cheklangan resurs	Himoya joyi
Hajmli L3/L4 trafik	Internet kanalining bit/s yoki paket/s sig‘imi	Provayder, trafikni tozalash xizmati
Ulanish holatiga bosim	TCP holat jadvali, ulanishlar, server resursi	Chegara qurilmasi va OT
Ko‘p HTTP so‘rovi	Ilova ishchilari, CPU, ma’lumotlar bazasi	Reverse proxy va ilova siyosati

DoS xizmatdan foydalanishni buzishga qaratiladi; DDoSda bir nechta manba qatnashadi. Katta trafik hajmi o‘z-o‘zidan hujum dalili emas: qonuniy talabning keskin oshishi ham kuzatiladi. Shu sababli trafik, xizmat holati va foydalanuvchi natijasi birga baholanadi. [1]

1.1. Darsdan oldin bajariladigan ishlar

VMware yoki VirtualBoxda yangi Ubuntu Server VM yarating yoki tayyor toza obraz nusxasidan foydalaning. Ubuntu o‘rnatishda oddiy administrator foydalanuvchisi yaratiladi. Paketlarni vaqtincha NAT adapter bilan o‘rnating:

```
sudo apt update
sudo apt install -y nginx python3 iproute2 curl nano
sudo systemctl stop nginx
nginx -v
python3 --version
```

Paketlar o‘rnatilgach VMning barcha virtual tarmoq kabellarini uzing (Cable connected/Connected belgisini olib tashlang). VM konsoli ishlashda davom etadi. Bridged adapter, NAT port forwarding yoki hostdagi Internet Connection Sharing kerak emas. Keyingi tarmoq faqat VM ichidagi virtual interfeyslardan tuziladi.

- A12-base snapshot oling. Har bir hostda aynan shu obrazdan mustaqil nusxa ishlatiladi; 30 talabada bir xil ichki IP manzillar takrorlanishi mumkin.
- O‘qituvchi hujjatdagi backend.py, probe.py va konfiguratsiya matnlarini oldindan tayyorlasa, 80 daqiqalik reja bajarilishi osonlashadi. Talaba buyruqlarni tushuntirib, asosiy parametrlarni o‘zi tekshiradi.
- Yangi o‘quv VMda boshqa veb-xizmat yoki eski firewall tajribasi bo‘lmasin. Firewallni ko‘r-ko‘rona o‘chirmang; ulanish muammosi bo‘lsa avval aynan lab manzillariga tegishli qoidalarni tekshiring.

1.2. Laboratoriya manzillari

Obyekt	Manzil	Vazifa
br-a12 (VM ichida)	10.120.10.1/24, TCP 80	Nginx kirish nuqtasi
a12-good namespace	10.120.10.11/24	8 ta oddiy so‘rov; so‘rovlar orasida 1 soniya
a12-test namespace	10.120.10.12/24	40 ta so‘rov; ko‘pi bilan 4 parallel ishchi
Backend (shu VMda)	127.0.0.1:8080	Faqat Nginx orqali olinadigan test javobi

Network namespace alohida tarmoq steki va marshrut jadvalini beradi, lekin VM fayl tizimini ajratmaydi. Shuning uchun barcha jarayonlar /opt/a12 fayllaridan foydalanadi. Mijozlarga default gateway berilmaydi.

2. Virtual tarmoq va backend yaratish

2.1. Alohida mijozlarni ulash

Quyidagi buyruqlar Ubuntu VM konsolida bajariladi. sudo -i dan keyingi barcha bloklar shu root sessiyada ishlatiladi. Buyruqlar birinchi toza ishga tushirish uchun; obyekt mavjud bo‘lsa, 9.2-bo‘limdagi yakunlash tartibini bajaring yoki snapshotga qayting.

```
sudo -i
mkdir -p /opt/a12/results
ip link add br-a12 type bridge
ip addr add 10.120.10.1/24 dev br-a12
ip link set br-a12 up
for item in good:11 test:12; do
  name=${item%:*}
  octet=${item#*:}
  ip netns add a12-$name
  ip link add v-$name type veth peer name c-$name
  ip link set v-$name master br-a12
  ip link set v-$name up
  ip link set c-$name netns a12-$name
  ip -n a12-$name link set lo up
  ip -n a12-$name link set c-$name up
  ip -n a12-$name addr add 10.120.10.$octet/24 dev c-$name
done
ip -br addr show br-a12
ip -n a12-good route
ip -n a12-test route
```

Natija: har mijozda faqat 10.120.10.0/24 lokal marshruti bor; default yozuvi yo‘q. Tashqi adapterlar br-a12 ga qo‘shilmaydi. IP forwarding yoki NATni yoqish talab etilmaydi. Bu sozlama rebootdan keyin yo‘qoladi; tajriba davomida VMni qayta yuklamang.

2.2. Kichik test ilovasi

Backend har GET uchun 0,2 soniya kutib, kichik javob beradi. Bu CPUni band qiladigan hisoblash emas, balki xizmat vaqtini ko‘rinadigan qilish uchun model. Python HTTP server faqat o‘quv muhiti uchun ishlatiladi.

```
cat > /opt/a12/backend.py <<'APP'
from http.server import BaseHTTPRequestHandler, ThreadingHTTPServer
import time
class App(BaseHTTPRequestHandler):
    def do_GET(self):
        time.sleep(0.2)
        body = b"A12 backend OK\n"
        self.send_response(200)
        self.send_header("Content-Type", "text/plain")
        self.send_header("Content-Length", str(len(body)))
        self.end_headers()
        self.wfile.write(body)
ThreadingHTTPServer(("127.0.0.1", 8080), App).serve_forever()
APP
chmod 644 /opt/a12/backend.py
```

2.3. Backendni alohida xizmat sifatida ishga tushirish

```
cat > /etc/systemd/system/a12-backend.service <<'UNIT'
[Unit]
Description=A12 local teaching backend
[Service]
User=www-data
ExecStart=/usr/bin/python3 /opt/a12/backend.py
Restart=on-failure
NoNewPrivileges=true
PrivateTmp=true
[Install]
WantedBy=multi-user.target
UNIT
systemctl daemon-reload
systemctl start a12-backend
systemctl is-active a12-backend
curl --noproxy '*' --max-time 3 http://127.0.0.1:8080/
ss -lntp 'sport = :8080'
```

Kutiladigan natija: xizmat active, javob A12 backend OK; tinglovchi faqat 127.0.0.1:8080. 0.0.0.0:8080 yoki 10.120.10.1:8080 ko‘rsatilmasligi kerak. Nginxni chetlab o‘tib backendga bevosita ulanish yo‘li shu tarzda yopiladi.

3. Nginxda kuzatuv va cheklov siyosati

3.1. Parametrlarni tanlash

Bir IP uchun rate=2r/s, burst=4 va nodelay tanlanadi: qisqa ortiqcha oqimning ruxsatli qismi kutmasdan o‘tadi, limitdan oshgan so‘rov esa 429 oladi. Bu “har sekundda aniq ikki so‘rov” degani emas; qisqa portlash va vaqt bo‘yicha limit holati ham hisobga olinadi. dry_run rejimida rad etilishi lozim bo‘lgan so‘rovlar faqat qayd etiladi. [2]

Parametr	Variant qiymati	Tanlash sababi
Bir IP uchun limit	2 so‘rov/s	Oddiy mijoz oqimidan yuqori
Qisqa portlash	burst=4, nodelay	Kichik keskin oqimni qabul qilish
Rad etish kodi	429	Siyosat rad javobini ajratish
So‘rov tanasi	16k	Bu oddiy test endpointi katta yuklama qabul qilmaydi
Backend kutish	proxy_read_timeout 3s	Test backendidagi 0,2 s dan ancha yuqori

Bu sonlar faqat o‘quv senariysi uchun. Ishlab turgan portalga aynan ko‘chirilmaydi: endpoint narxi, foydalanuvchi soni, NAT ortidagi guruhlar va haqiqiy yuklama o‘lchovi asosida qayta tanlanadi. So‘rov/s bilan bit/s turli o‘lchovlardir. [3]

3.2. Alohida Nginx nusxasi

Asosiy nginx xizmatini to‘xtatganimiz sababli lab konfiguratsiyasini /opt/a12/nginx.conf orqali alohida ishga tushiramiz. Tizimdagi nginx.conf tahrirlanmaydi. Keyingi sahifadagi fayl to‘liq asosiy konfiguratsiyadir; uni sites-enabled ichiga joylamang.

Nginx 10.120.10.1:80 da tinglaydi va 127.0.0.1:8080 ga proxy qiladi. Shunday qilib, rate limit haqiqiy backendga uzatishdan oldin ishlaydi. location ichida return 200 bilan sun’iy javob berish bu tekshiruv uchun mos emas.

3.3. To‘liq konfiguratsiyani yozish

```
cat > /opt/a12/nginx.conf <<'CONF'
user www-data;
worker_processes 1;
pid /run/a12-nginx.pid;
error_log /opt/a12/error.log notice;
events { worker_connections 256; }
http {
  log_format a12 escape=json
    '{"time":"$time_iso8601","ip":"$remote_addr",'
    '"uri":"$request_uri","status":$status,'
    '"rt":$request_time,"up":"$upstream_status",'
    '"limit":"$limit_req_status"}';
  access_log /opt/a12/access.jsonl a12;
  limit_req_zone $binary_remote_addr zone=a12_ip:1m rate=2r/s;
  server {
    listen 10.120.10.1:80;
    server_name a12.test;
    client_max_body_size 16k;
    client_header_timeout 5s;
    client_body_timeout 5s;
    keepalive_timeout 5s;
    location / {
      limit_req zone=a12_ip burst=4 nodelay;
      limit_req_status 429;
      limit_req_log_level notice;
      limit_req_dry_run on;
      proxy_pass http://127.0.0.1:8080;
      proxy_set_header Host $host;
      proxy_set_header X-Real-IP $remote_addr;
      proxy_set_header X-Forwarded-For $remote_addr;
      proxy_connect_timeout 1s;
      proxy_read_timeout 3s;
      proxy_send_timeout 3s;
    }
  }
}
CONF
nginx -t -c /opt/a12/nginx.conf
nginx -c /opt/a12/nginx.conf
ip netns exec a12-good curl --noproxy '*' --max-time 3 \
  -i http://10.120.10.1/?run=setup
ss -lntp 'sport = :80'
```

Kutiladigan natija: syntax is ok / test is successful, HTTP 200 va A12 backend OK. access.jsonl ichida ip=10.120.10.11 hamda up=200 chiqadi. Logdagi up backend HTTP holatini, limit esa limit modulining qarorini ko‘rsatadi. [2, 4, 5]

HTTP bu yerda ajratilgan labdagi so‘rovlarni tahlil qilish uchun ishlatiladi. Real portal loyihasida TLS tugatiladigan nuqta va sertifikat boshqaruvi ham ko‘rsatiladi. Timeoutlar to‘liq so‘rovning qat’iy umumiy muddatini bermaydi; masalan, proxy_read_timeout ketma-ket o‘qishlar orasidagi kutishga tegishli. [4]

4. Chegaralangan mijoz va takrorlanadigan sinov

4.1. Sinov dasturi — /opt/a12/probe.py

Quyidagi matnni nano /opt/a12/probe.py orqali saqlang (Ctrl+O, Enter, Ctrl+X). Manzil kodda belgilangan; boshqa nishon parametri yo‘q. fast rejim 40 ta so‘rov va 4 ishchi bilan tugaydi; normal rejim 8 ta ketma-ket so‘rov yuboradi. Internet proxy sozlamalari ishlatilmaydi.

```
import csv, sys, time
from concurrent.futures import ThreadPoolExecutor
from urllib.request import build_opener, ProxyHandler, Request
from urllib.error import HTTPError
mode, tag, out = sys.argv[1:]
if mode not in ("normal", "fast") or tag not in ("before", "after"):
    raise SystemExit("Rejim yoki bosqich noto'g'ri")
url = "http://10.120.10.1/?run=" + tag

def one(i):
    start = time.monotonic()
    status = "ERR"
    try:
        op = build_opener(ProxyHandler({}))
        req = Request(url, headers={"Connection": "close"})
        with op.open(req, timeout=3) as response:
            status = str(response.status)
            response.read()
    except HTTPError as exc:
        status = str(exc.code)
        exc.read()
        exc.close()
    except Exception as exc:
        status = "ERR_" + type(exc).__name__
    ms = round((time.monotonic() - start) * 1000, 2)
    return [i, status, ms]

begin = time.monotonic()
if mode == "fast":
    with ThreadPoolExecutor(max_workers=4) as pool:
        rows = list(pool.map(one, range(1, 41)))
else:
    rows = []
    for i in range(1, 9):
        rows.append(one(i))
        if i < 8:
            time.sleep(1)
with open(out, "w", newline="") as f:
    writer = csv.writer(f)
    writer.writerow(["id", "status", "ms"])
    writer.writerows(rows)
print(mode, tag, "N=", len(rows),
      "elapsed_s=", round(time.monotonic() - begin, 2))
```

Chegara: bir tajriba juftligida jami 48 ta so‘rov; ikkita asosiy bosqichda 96 ta. Har bosqich uchun tashqi timeout 45 soniya. Testni cheksiz siklga aylantirmang va parametrlarni oshirmang. Konsolda Ctrl+C yoki timeout orqali jarayonni to‘xtatish mumkin.

```
python3 -m py_compile /opt/a12/backend.py /opt/a12/probe.py
```

4.2. “Oldin” bosqichi — faqat kuzatuv

Har bosqich boshlanishidan avval kamida 5 soniya yangi so‘rov yubormang. Quyidagi ikkita jarayon bir vaqtda ishga tushadi; alohida IPli oddiy mijoz natijasi tezkor mijozdan ajratib saqlanadi. Buyruqlar root konsolida bajariladi.

```
sleep 5
timeout 45s ip netns exec a12-good python3 /opt/a12/probe.py \
 normal before /opt/a12/results/good-before.csv &
GOOD_PID=$!
timeout 45s ip netns exec a12-test python3 /opt/a12/probe.py \
 fast before /opt/a12/results/test-before.csv
wait "$GOOD_PID"
grep 'REJECTED' /opt/a12/access.jsonl | tail -n 6
```

Kutiladigan natija: xizmat sog‘lom bo‘lsa ikkala CSVdagi so‘rovlar 200 oladi; ayrim tezkor so‘rovlar logda REJECTED_DRY_RUN bo‘lishi mumkin. Bu ularning amalda bloklanganini bildirmaydi: up=200 ekanini tekshiring. 5xx yoki ERR chiqsa, “himoyasiz tizim yiqildi” deb yozmasdan sababini aniqlang.

4.3. “Keyin” bosqichi — cheklovni faollashtirish

```
cp /opt/a12/nginx.conf /opt/a12/nginx-before.conf
sed -i 's/limit_req_dry_run on;/limit_req_dry_run off;/' \
 /opt/a12/nginx.conf
nginx -t -c /opt/a12/nginx.conf && \
 nginx -s reload -c /opt/a12/nginx.conf
sleep 5
timeout 45s ip netns exec a12-good python3 /opt/a12/probe.py \
 normal after /opt/a12/results/good-after.csv &
GOOD_PID=$!
timeout 45s ip netns exec a12-test python3 /opt/a12/probe.py \
 fast after /opt/a12/results/test-after.csv
wait "$GOOD_PID"
grep 'REJECTED' /opt/a12/access.jsonl | tail -n 8
```

Kutiladigan natija: oddiy mijoz 8/8 marta 200 oladi; tezkor mijozda 200 bilan birga 429 paydo bo‘ladi. Nginx logida 429 qatorining limit=REJECTED va up=- ekanligi so‘rov backendga yuborilmaganini ko‘rsatadi. Rad etilganlar aniq soni VM tezligi va ishga tushirish vaqtiga bog‘liq; oldindan qat’iy son qo‘ymang.

4.4. Qabul qilish mezoni

- To‘rtta CSV mavjud: har good faylida 8 ta, har test faylida 40 ta ma’lumot qatori.
- Oddiy mijozning “keyin” bosqichida 429, 5xx yoki ERR yo‘q; tezkor mijozning kamida bitta so‘rovi 429 bilan cheklangan.
- before bosqichidagi kuzatuv qarori va after bosqichidagi haqiqiy rad etish access.jsonl bilan tasdiqlangan.
- Kutilgan natija chiqmasa “o‘tdi” deb belgilamang; konfiguratsiya, vaqt va xizmat holatini tekshiring.

5. Natijalarni hisoblash va qo‘shimcha tekshiruvlar

5.1. CSVlarni umumlashtirish

```
python3 - <<'METRICS'
import csv, glob, math
from collections import Counter
for file in sorted(glob.glob('/opt/a12/results/*.csv')):
    with open(file) as f:
        rows = list(csv.DictReader(f))
    n = len(rows)
    counts = Counter(r['status'] for r in rows)
    ok = sorted(float(r['ms']) for r in rows if r['status'] == '200')
    p95 = ok[math.ceil(0.95 * len(ok)) - 1] if ok else None
    success = round(100 * counts['200'] / n, 1) if n else None
    print(file.rsplit('/', 1)[-1], 'N=', n, dict(counts),
          'success_%=', success, 'p95_200_ms=', p95)
METRICS
```

Muvaffaqiyat ulushi = N200 / Njami × 100%. Rad etish ulushi = N429 / Njami × 100%. p95 faqat muvaffaqiyatli 200 javoblar kechikishidan hisoblanadi; tez qaytgan 429 larni qo‘shish noto‘g‘ri “tezlashish” taassurotini berishi mumkin. 8 ta kuzatuvli p95 — kichik tanlama, real portal SLOsini isbotlamaydi.

Bosqich / mijoz	N	200	429	5xx / ERR	p95 200, ms
Oldin / good	8	____	____	____	____
Oldin / test	40	____	____	____	____
Keyin / good	8	____	____	____	____
Keyin / test	40	____	____	____	____

5.2. Backendni aylanib o‘tish yo‘lini tekshirish

```
ip netns exec a12-test curl --noproxy '*' --max-time 3 \
 http://10.120.10.1:8080/
sleep 5
ip netns exec a12-good curl --noproxy '*' --max-time 3 \
 -i http://10.120.10.1/?run=final
```

Birinchi ulanish bajarilmasligi, ikkinchisi HTTP 200 berishi kerak. Birinchi natijani 8080 faqat loopbackda tinglayotgani haqidagi ss dalili bilan birga talqin qiling; yolg‘iz timeout yetarli sabab ko‘rsatmaydi.

5.3. Mijoz IPiga ishonch chegarasi

```
sleep 5
ip netns exec a12-test curl --noproxy '*' --max-time 3 \
 -H 'X-Forwarded-For: 192.0.2.55' \
 'http://10.120.10.1/?run=xff'
tail -n 1 /opt/a12/access.jsonl
```

Logdagi ip 10.120.10.12 bo‘lib qolishi kerak. Labda real_ip_header yoqilmagan; mijoz yuborgan X-Forwarded-For limit kalitini o‘zgartirmaydi. CDN ortida faqat ma’lum ishonchli proksilarning IP diapazonlariga ishonish va origin kirishini cheklash zarur. [6]

6. 1-variantning DDoS himoya loyihasi

6.1. Berilgan ishlab chiqarish senariysi

Quyidagi raqamlar loyihalash uchun shartli berilgan, laboratoriyada o‘lchangan emas: portal uplinki 100 Mbit/s, odatiy eng yuqori kiruvchi trafik 40 Mbit/s, ilovaning barqaror ishlashi oldindan 200 so‘rov/s gacha tasdiqlangan. Bir NAT manzili ortida 30 talaba bor; har biri 0,5 so‘rov/s yuboradi. Ehtimoliy hajmli hujum 1 Gbit/s; boshqa senariyda 1000 manbaning har biri 2 so‘rov/s yuboradi.

1. Kanal zaxirasini hisoblang: 100 − 40 = ____ Mbit/s. 1 Gbit/s ni Mbit/s ga aylantirib, uplinkdan necha marta katta ekanini toping.
2. NAT ortidagi 30 talabaning jami tezligini hisoblang. Laboratoriyadagi 2r/s IP limiti ularni nega noto‘g‘ri cheklashini izohlang.
3. 1000 ta manbaning yig‘indi so‘rov tezligini hisoblang va 200 so‘rov/s ilova sig‘imi bilan solishtiring. Har IP o‘z limitidan oshmasa ham qanday muammo yuzaga keladi?
4. Ilova uchun 20% zaxira qoldirilsa, global qabul chegarasining boshlang‘ich nomzodi nechaga teng? Bu faqat taklif ekanini, real endpoint xarajati bilan qayta sinov zarurligini yozing.

6.2. Qatlamli choralarni tanlash

Qatlam	Loyihaga kiritiladigan chora	Dalil yoki cheklov
Provayder	Upstream filtrlash yoki trafikni tozalash; xizmat va aloqa shartlari	Kanal to‘lishidan oldin filtrlash; faqat mahalliy Nginx yetmaydi
Chegara / origin	CDN/reverse proxy; originni faqat ishonchli manbalarga ochish	Origin IPga bevosita kirish sinovi; CDN barcha protokollarni avtomatik himoyalamaydi
HTTP / ilova	Endpoint va foydalanuvchi bo‘yicha limit; global sig‘im cheklovi	NAT, autentifikatsiya va endpoint narxini hisobga olish
Resurslar	Mos timeout, ulanish cheklovi, statik kontent keshi	Har biri uchun o‘lchov va qaytarish mezoni
Monitoring	Kanal bit/s, paket/s, 5xx, p95, backend bandligi va normal mijoz 200 ulushi	429 ulushi yolg‘iz o‘zi hujum tasdig‘i emas

Tanlov izohi. Global limit ilovaning umumiy sig‘imini saqlashga yordam beradi, lekin hujumchi limitni band qilsa oddiy mijozlar ham rad etilishi mumkin. Shu bois hisob/endpoint bo‘yicha adolatli taqsimlash, ishonchli proksi, kesh va yuqori tarmoq qatlamidagi himoya birgalikda ko‘riladi. [1, 3]

Talaba loyihasi: kamida 5 ta chora uchun “qayerda ishlaydi — qanday signalda yoqiladi — kim javobgar — qaysi dalil bilan tekshiriladi — qachon qaytariladi” ketma-ketligida qisqa izoh yozing. Internetdagi xizmatni sotib olish yoki real tarmoqqa o‘zgartirish kiritish talab qilinmaydi.

7. Hodisaga javob berish va mustaqil topshiriqlar

7.1. Portal uchun qisqa javob rejasi

Quyidagi vaqtlar o‘quv senariysi uchun maqsadli muddatlar. Real tashkilotda xizmat talabi va mas’ullar bilan kelishiladi. NCSC xizmatni tushunish, himoya imkoniyatlarini bilish, javob rejasini tayyorlash va uni sinashni birgalikda ko‘rishni tavsiya qiladi. [1]

Bosqich	Mas’ul	Harakat va tekshiruv
0–5 daqiqa	Navbatchi administrator	Normal mijoz sinovi, kanal va 5xx/p95; deploy yoki backend nosozligini ajratish
5–10 daqiqa	Tarmoq mutaxassisi	Kanal bandligi bo‘lsa provayderga vaqt, nishon va metrikalarni berish; tashqi aloqa yo‘li
5–15 daqiqa	Ilova administratori	Oldindan sinovdan o‘tgan endpoint/global siyosatni yoqish; normal mijoz xatolarini kuzatish
Barqarorlashgach	Hodisa koordinatori	Masalan 10 daqiqa sog‘lom xizmatdan so‘ng cheklovni bosqichma-bosqich yumshatish
Hodisa yakuni	Mas’ullar guruhi	Dalillarni saqlash, ta’sir vaqtini hisoblash, qoidalar va aloqa rejasini yangilash

Eskalatsiya uchun boshlang‘ich o‘quv signali: uplink 80% dan yuqori band bo‘lib 3 daqiqa davom etsa yoki normal mijoz muvaffaqiyati 95% dan pasaysa — sabab tekshiruvi boshlanadi. Bular universal chegaralar emas. 429 ni butunlay yo‘qotish maqsad emas; qonuniy xizmat mavjudligini saqlash maqsaddir.

7.2. Bajariladigan 1-variant topshiriqlari

1. A12 topologiyasini yarating, ikkala mijoz IPsi va default route yo‘qligini qayd eting. Backend faqat 127.0.0.1:8080 da tinglasin.
2. Nginx konfiguratsiyasini kuzatuv rejimida ishga tushiring. Limit kaliti, rate, burst va log maydonlarini tushuntiring.
3. Bir xil mijoz dasturi bilan before va after bosqichlarini bajaring. Har bosqichda oddiy va tezkor mijoz bir vaqtda qatnashsin.
4. To‘rtta CSVni umumlashtiring; 200, 429, 5xx/ERR va p95 natijalarini yozing. Ikki rejim loglarini solishtiring.
5. Backendni bevosita chaqirish rad etilganini va X-Forwarded-For haqiqiy mijoz IPini almashtirmaganini tekshiring.
6. 6.1-bo‘limdagi to‘rtta hisobni bajaring; NAT va ko‘p manbali trafik uchun cheklovlarni ochib bering.
7. Kamida beshta himoya chorasi, uchta kuzatuv ko‘rsatkichi va qaytarish sharti bo‘lgan loyihani topshiring.

Qo‘shimcha tahlil — vaqt qolsa

burst kattaroq bo‘lsa qonuniy keskin oqim va backendga dastlabki bosim qanday o‘zgarishini taxmin qiling. global limitni alohida umumiy kalit bilan qo‘shish loyihasini yozing, lekin asosiy tajriba o‘rtasida bir nechta parametrni birvarakayiga o‘zgartirmang. Qo‘shimcha trafik yuborish majburiy emas.

8. Hisobot, vaqt taqsimoti va baholash

8.1. Topshiriladigan dalillar

- Titul: F.I.Sh., guruh, sana, fan, 5-semestr, A12, 1-variant; VM va dastur versiyalari.
- S1: hypervisorda tarmoq kabellari uzilgan holat; br-a12, ikkala namespace IP va route natijalari.
- S2: nginx -t muvaffaqiyati, 80/8080 tinglovchilari va oddiy HTTP 200 javobi.
- S3: before va after rejimlaridan vaqt, manba IP, status, up, limit ko‘rinadigan log qatorlari.
- S4: to‘rtta CSV bo‘yicha umumlashtirish; S5: backendga bevosita ulanish rad javobi va XFF tekshiruvi.
- Hisob-kitoblar va himoya loyihasi; 6–8 gaplik xulosa: nimani o‘lchadingiz, nimani bu tajriba isbotlamaydi.

Elektron dalillar: nginx.conf, nginx-before.conf, backend.py, probe.py, results papkasidagi CSVlar, access.jsonl va error.log. Hisobotga taxminiy yoki namunaviy sonlarni tajriba natijasi deb kiritmang. Xatoli tekshiruvni ham sabab va tuzatish bilan qayd eting.

8.2. Tavsiya etilgan 80 daqiqalik taqsimot

Ish	Daqiqa	Yakuniy dalil
Muhit va topologiyani tekshirish	10	IP/route va ajratilgan tarmoq
Backend va Nginxni sozlash	15	200 javob va konfiguratsiya testi
Ikki bosqichli tajriba	15	4 ta CSV va loglar
Hisoblash va qo‘shimcha tekshiruv	10	Natija jadvali, backend/XFF dalili
Himoya loyihasi va hisoblar	20	Qatlamli choralar va javob rejasi
Hisobotni tartiblash va himoya	10	Xulosa va qisqa savol-javob
Jami	80	Paket va matnlar oldindan tayyor holatda

8.3. Baholash mezoni — 10 ball

Mezon	Ball	To‘liq ball uchun talab
Ajratish va topologiya	1	Ikki manba IPsi, default route yo‘q, backend loopbackda
Nginx siyosati	2	To‘g‘ri kalit, kuzatuv/faol rejim, 429 va log maydonlari
Nazoratli tajriba	2	4 ta to‘liq CSV; normal 8/8; tezkor 429 va log tasdig‘i
Natijalarni tahlil qilish	1	Ulushlar, p95 cheklovi, rad javobi va nosozlik farqi
DDoS himoya loyihasi	3	4 hisob, kamida 5 chora, NAT/kanal cheklovi, javob rejasi
Dalillar va himoya	1	Tekshiriladigan hisobot va mustaqil izoh

80 daqiqa qat’iy cheklov emas. Dasturlar yoki fayllar darsning o‘zida tayyorlansa qo‘shimcha vaqt ajratiladi; himoya loyihasi qismini faqat kod ko‘chirish hisobiga qisqartirmang.

9. Nosozliklarni aniqlash va ishni yakunlash

Belgi	Tekshirish	Tuzatish yo‘li
File exists: br-a12	ip link, ip netns list	Eski labni quyidagi tartibda tugating yoki snapshotga qayting
nginx -t xatosi	Fayl, satr raqami, nginx -v	Qavs/nuqtali vergul va asosiy konfiguratsiya joyini tekshiring
HTTP 502	systemctl status a12-backend; ss	Backendni ishga tushiring; proxy manzili 127.0.0.1:8080
HTTP 503 kutilmaganda	nginx.conf, error.log	Lab konfiguratsiyasi va limit_req_status 429 ishlayotganini tekshiring
after bosqichida 429 yo‘q	dry_run, reload, fast CSV	off rejimni va 40 so‘rovni tekshiring; sintaksis xatosida reload bo‘lmagan bo‘lishi mumkin
good ham 429 oladi	Logdagi ip va sinov oralig‘i	Mijozlar bir namespacega tushmaganini va 5 soniyalik tanaffusni tekshiring
CSV yo‘q yoki to‘liq emas	Dastur chiqishi, timeout kodi	Xizmat muammosini tuzating; faqat buzilgan bosqichni takrorlang

9.1. Konfiguratsiyani qaytarish

Faol siyosat muammo tug‘dirsa, VM konsolida avvalgi kuzatuv konfiguratsiyasini qaytaring. Bu faqat laboratoriya uchun: real portalda cheklovni bekor qilish qarori xizmat ko‘rsatkichlari va hodisa koordinatori bilan bog‘lanadi.

```
cp /opt/a12/nginx-before.conf /opt/a12/nginx.conf
nginx -t -c /opt/a12/nginx.conf && \
 nginx -s reload -c /opt/a12/nginx.conf
```

9.2. Dalillarni saqlash va labni tozalash

Avval hisobot va /opt/a12 dagi dalillarni hostdagi A12 papkasiga oldindan sozlangan shared folder orqali ko‘chiring. Sinov jarayonlari tugagan bo‘lsin. Keyin faqat A12 obyektlarini quyidagi tartibda olib tashlang:

```
nginx -s quit -c /opt/a12/nginx.conf
systemctl stop a12-backend
ip netns del a12-good
ip netns del a12-test
ip link del br-a12
rm /etc/systemd/system/a12-backend.service
systemctl daemon-reload
```

Bu buyruqlar /opt/a12 dalillarini o‘chirmaydi. Nginx to‘xtashi tugaganini ps orqali tekshiring. Snapshotga qaytish dalillarni yo‘qotishi mumkin, shuning uchun eksportdan keyin bajaring. Takroriy ishni toza snapshotdan boshlash tavsiya etiladi.

10. O‘qituvchi uchun himoya savollari

1. DoS va DDoSning farqi nimada? Biz bajargan tajribada ko‘p manbali DDoS o‘lchandimi?
2. Nima uchun backendga 127.0.0.1:8080 berilgan? Faqat 80-portdagi limit originni o‘zi himoyalay oladimi?
3. dry_run rejimida REJECTED_DRY_RUN bilan up=200 birga chiqishi nimani anglatadi?
4. burst=4 va nodelay parametrlarini vaqt bo‘yicha izohlang. 2r/s qiymati bir zumdagi barcha oqimni ikkiga tushiradimi?
5. Nima uchun oddiy mijoz alohida IPdan va tezkor mijoz bilan bir vaqtda tekshiriladi?
6. HTTP 429 tez javob berishi tizimning foydalanuvchilar uchun tezlashganini anglatadimi?
7. Nima uchun mijoz yuborgan X-Forwarded-For sarlavhasiga avtomatik ishonish mumkin emas?
8. NAT ortidagi 30 talaba uchun IP bo‘yicha 2r/s limitning ta’siri qanday?
9. 100 Mbit/s kanal 1 Gbit/s kiruvchi trafik bilan to‘lsa, lokal Nginx nimani hal qila olmaydi?
10. Global so‘rov limiti backendni saqlasa ham qonuniy mijozlar nima sababdan rad etilishi mumkin?
11. Normal foydalanuvchi mavjudligini qaysi metrikalar bilan isbotlaysiz va qaysi signalda siyosatni qaytarasiz?
12. Ushbu laboratoriyadan olingan natijalarni real portal sig‘imiga ko‘chirish uchun yana qanday o‘lchovlar kerak?

Hisob-kitoblar bo‘yicha o‘qituvchi kaliti

6.1-bo‘lim: kanal zaxirasi 60 Mbit/s; 1 Gbit/s = 1000 Mbit/s, uplinkdan 10 marta katta. NAT ortidagi talabalar 15 so‘rov/s yuboradi. 1000 manba jami 2000 so‘rov/s hosil qiladi, bu berilgan 200 so‘rov/s sig‘imdan 10 marta katta. 20% zaxira bilan global chegara nomzodi 200 × 0,8 = 160 so‘rov/s. Bu nominal hisoblar burst, trafik tarkibi va resurs narxining o‘rnini bosmaydi.

Foydalanilgan rasmiy manbalar

[1] NCSC. Denial of Service (DoS) guidance. https://www.ncsc.gov.uk/collection/denial-service-dos-guidance-collection

[2] Nginx. ngx_http_limit_req_module: kalit, burst, dry_run va qaror holatlari. https://nginx.org/en/docs/http/ngx_http_limit_req_module.html

[3] NGINX. Limiting Access to Proxied HTTP Resources. https://docs.nginx.com/nginx/admin-guide/security-controls/controlling-access-proxied-http/

[4] Nginx. ngx_http_proxy_module: backendga uzatish va timeoutlar. https://nginx.org/en/docs/http/ngx_http_proxy_module.html

[5] Nginx. ngx_http_log_module: log_format va JSON escape. https://nginx.org/en/docs/http/ngx_http_log_module.html

[6] Nginx. ngx_http_realip_module: ishonchli proksi va haqiqiy IP. https://nginx.org/en/docs/http/ngx_http_realip_module.html

Yakuniy qayd. Muvaffaqiyat mezoni ko‘p so‘rov yuborish emas, balki tanlangan himoya qanday ishlaganini dalillar bilan ko‘rsatish va uning amaliy chegaralarini to‘g‘ri loyihalashdir.